

ENTERPRISE PHISHING INCIDENT RESPONSE REPORT

Prepared For: NAD Cybersecurity Institute

Prepared By: Daniel Nwachukwu SOC Analyst | Threat Intelligence | Incident Response | Threat Hunting

Report Date: 26 July 2026

Classification: Confidential

Frameworks: MITRE ATT&CK Framework | NIST SP 800-61 Incident Response Lifecycle

1. Executive Summary

This report documents the investigation of a simulated enterprise phishing attack conducted in a controlled laboratory environment. The attack progressed through multiple stages, including reconnaissance, initial access, exploitation, privilege escalation, persistence, defense evasion, discovery, collection, attempted exfiltration, and lateral movement.

Security events were investigated using Splunk Enterprise, Wazuh SIEM, Sysmon, Snort IDS, and pfSense. Threat intelligence from VirusTotal, AbuseIPDB, and PhishTool was used to validate indicators of compromise.

The investigation successfully reconstructed the complete attack lifecycle, contained the threat, removed persistence mechanisms, and restored the environment to a secure state. The findings highlight the importance of centralized monitoring, layered security controls, and structured incident response.

2. Business Challenge

NAD Cybersecurity Institute recently launched a cloud-based student portal for admissions, course registration, and learning resources. An employee in the Admissions Department received an email impersonating Microsoft requesting urgent account verification. The email contained a link to a malicious website (example.com). After the employee clicked the link, security monitoring platforms began detecting suspicious activity across multiple systems. The SOC team must investigate the incident, determine the attack timeline, contain the compromise, eradicate persistence, recover affected systems, and produce a complete incident response report.

3.Methodology

A structured Digital Forensics and Incident Response (DFIR) methodology was adopted to simulate, detect, investigate, and remediate a phishing attack within a controlled lab environment.

The engagement began with simulating attacker activities, including reconnaissance, phishing, exploitation, privilege escalation, persistence, defense evasion, discovery, collection, exfiltration, and lateral movement. Security events were captured using Splunk Enterprise, Wazuh SIEM, Sysmon, Snort IDS, and pfSense.

Logs from endpoint, network, authentication, and web server sources were centralized and correlated to reconstruct the attack timeline. Indicators of Compromise (IOCs) were validated using VirusTotal, AbuseIPDB, PhishTool, and MXToolbox, while attacker behaviors were mapped to the MITRE ATT&CK Framework.

Finally, the NIST SP 800-61 Incident Response Lifecycle was applied to perform containment, eradication, recovery, and post-incident documentation, resulting in a comprehensive incident response report and technical evidence repository.

4.Project Scope

This project focused on simulating and investigating a complete enterprise phishing attack within a controlled cybersecurity lab environment. The scope covered the full incident response lifecycle, including reconnaissance, initial access, exploitation, privilege escalation, persistence, defense evasion, discovery, collection, exfiltration, lateral movement, containment, eradication, and recovery.

The investigation involved collecting and correlating logs from Splunk Enterprise, Wazuh SIEM, Sysmon, Snort IDS, pfSense, Ubuntu Server, and Windows 11 to identify malicious activities and reconstruct the attack timeline. Threat intelligence platforms, including VirusTotal, AbuseIPDB, PhishTool, and MXToolbox, were used to validate Indicators of Compromise (IOCs) and enrich the investigation.

The project concluded with IOC analysis, MITRE ATT&CK mapping, implementation of the NIST SP 800-61 Incident Response Lifecycle, and the production of a professional incident response report documenting the findings, response actions, and security recommendations.

4.1 Investigation Outcome

- Attack successfully detected
- Complete attack timeline reconstructed
- Persistence removed
- Environment recovered
- Security recommendations provided

4.2 Environment Overview

Overview

The investigation was conducted within a controlled enterprise cybersecurity laboratory designed to simulate a real-world phishing attack. The environment consisted of attacker, target, monitoring, and security infrastructure to enable end-to-end incident detection and response.

Lab Components

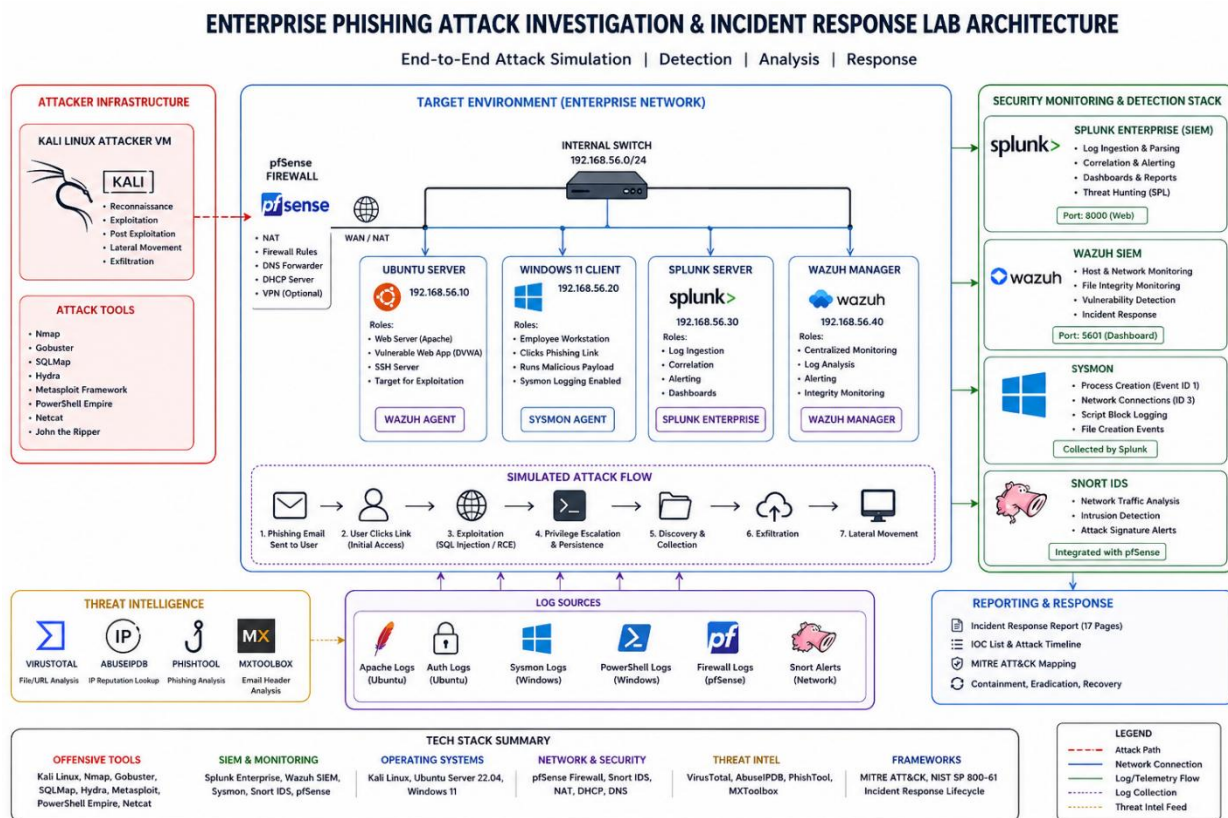
Component	Purpose
Kali Linux	Attacker machine
Ubuntu Server	Target system hosting the vulnerable application
Windows 11	Endpoint monitored with Sysmon
Splunk Enterprise	SIEM for log analysis and correlation
Wazuh SIEM	Endpoint detection and monitoring
Snort IDS	Network intrusion detection
pfSense	Firewall and network segmentation

4.3 Investigation Scope

The investigation covered the complete attack lifecycle:

- Reconnaissance
- Initial Access
- Exploitation
- Privilege Escalation
- Persistence
- Defense Evasion
- Discovery
- Collection
- Exfiltration
- Lateral Movement
- Containment
- Eradication
- Recovery

Figure 1 – Lab Architecture



4.4 Incident Timeline

Overview

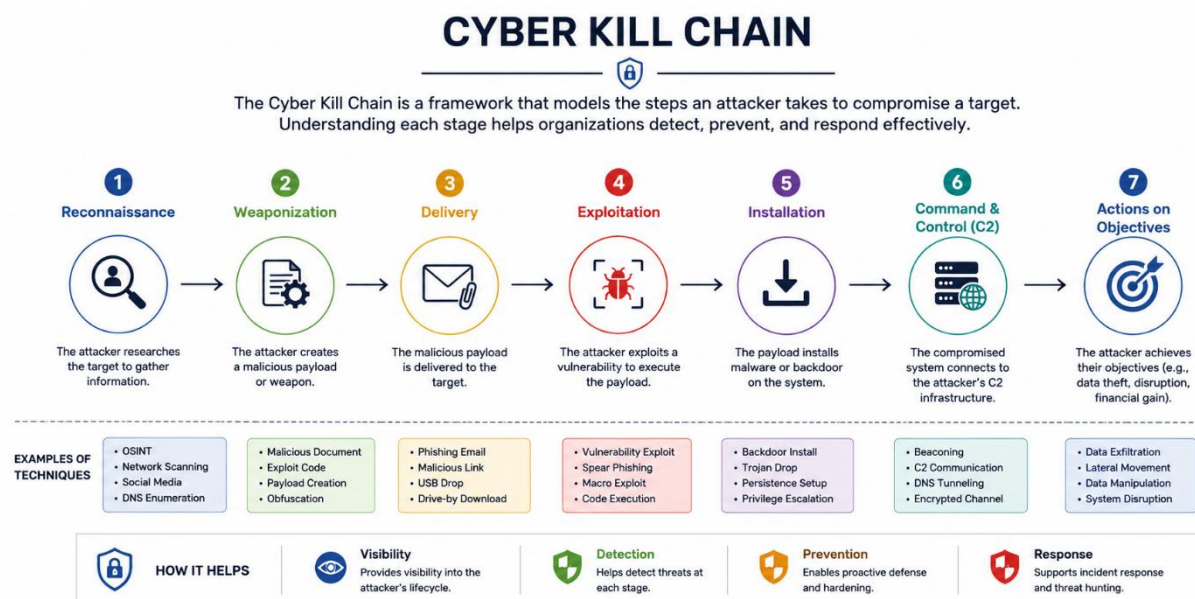
The timeline below summarizes the key events observed during the investigation, from the initial reconnaissance to full recovery. Events were reconstructed using Splunk, Wazuh, Sysmon, Snort IDS, and supporting threat intelligence.

Phase	Activity	Detection
Reconnaissance	Web directory enumeration using Gobuster	Wazuh
Initial Access	Phishing email delivered and SSH access obtained	Wazuh, Splunk
Exploitation	SQL Injection executed using SQLMap	Wazuh, Snort IDS
Privilege Escalation	Root privileges obtained via sudo	Wazuh
Persistence	Cron job and SSH authorized_keys modified	Wazuh, Splunk

Phase	Activity	Detection
Defense Evasion	Encoded PowerShell and LOLBins executed	Splunk, Sysmon
Discovery	User, network, and file enumeration	Splunk
Collection	Sensitive files identified and staged	Splunk
Exfiltration	Attempted HTTP data transfer	Splunk, Wazuh
Lateral Movement	SSH and remote services used	Splunk, Sysmon
Containment	Compromised host isolated	SOC Team
Eradication	Persistence removed and credentials reset	SOC Team
Recovery	Monitoring validated and systems restored	SOC Team

Figure 2 – Attack Timeline

Phishing → Initial Access → Exploitation → Privilege Escalation → Persistence → Defense Evasion → Discovery → Collection → Exfiltration → Lateral Movement → Containment → Recovery



5. Investigation Methodology

Overview

The incident was investigated using a structured Digital Forensics and Incident Response (DFIR) methodology. Evidence was collected from multiple sources, correlated to reconstruct the attack timeline, and validated against the MITRE ATT&CK Framework.

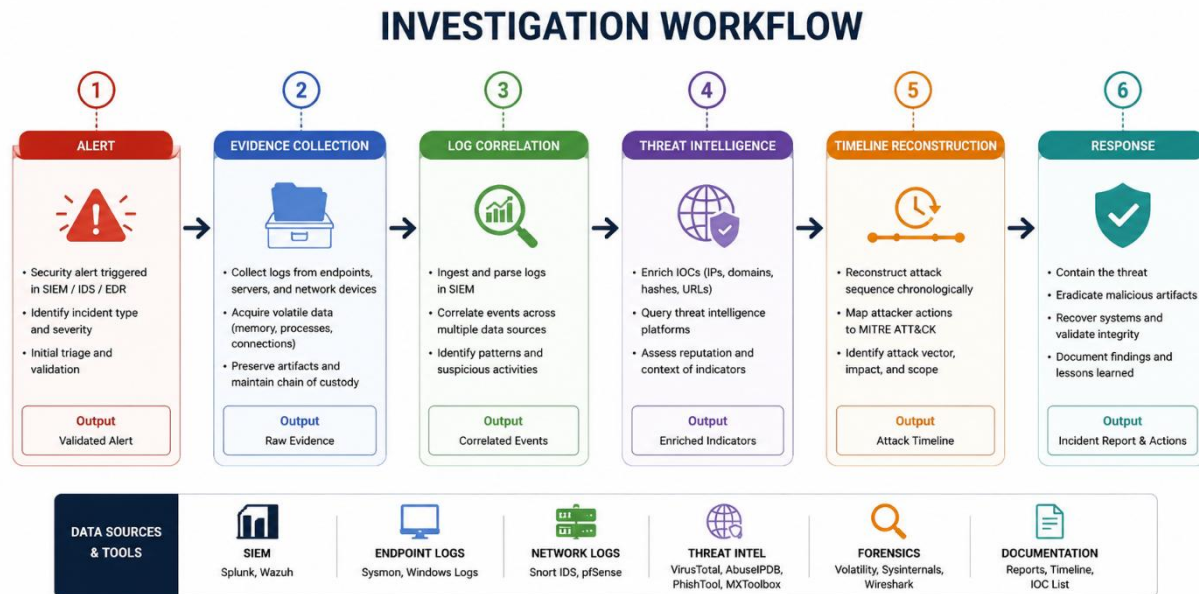
Evidence Sources

Source	Purpose
Splunk Enterprise	Log analysis and event correlation
Wazuh SIEM	Endpoint monitoring and alerting
Sysmon	Process, network, and DNS telemetry
Snort IDS	Network intrusion detection
Linux Logs	Authentication and system events
Threat Intelligence	IOC validation using VirusTotal, AbuseIPDB, MXToolbox, and PhishTool

Investigation Process

- Review security alerts.
- Correlate events across multiple log sources.
- Validate indicators using threat intelligence.
- Reconstruct the attack timeline.
- Map attacker activity to the MITRE ATT&CK Framework.
- Perform containment, eradication, and recovery.
- Investigation Outcome

Evidence from endpoint, network, and threat intelligence sources confirmed the complete attack lifecycle. Cross-validation of events improved confidence in the findings and reduced false positives.



Technical Findings

The investigation identified multiple malicious activities across the enterprise environment, confirming a successful multi-stage attack simulation.

1. Phishing Attack Successfully Executed

- A phishing email served as the initial attack vector.
- User interaction initiated the compromise.
- Email artifacts were validated using threat intelligence platforms.

2. Unauthorized SSH Access

- Successful SSH authentication was observed from the attacker system.
- Authentication logs confirmed unauthorized remote access.

3. Web Application Exploitation

- SQL Injection attacks were successfully executed using SQLMap.
- Abnormal HTTP requests were detected by Snort IDS and Wazuh.

4. Privilege Escalation

- The attacker obtained elevated (root) privileges using sudo.
- System logs confirmed successful privilege escalation.

5. Persistence Mechanisms Established

- Unauthorized cron jobs were created.
- The authorized_keys file was modified to maintain SSH access.

6. Defense Evasion Techniques Observed

- Encoded PowerShell commands were executed.
- Legitimate system utilities (LOLBins) were abused to evade detection.

7. System Discovery Performed

- The attacker enumerated users, directories, services, and network configurations.
- Discovery commands were successfully captured by endpoint monitoring.

8. Data Collection and Staging

- Sensitive files were identified and archived prior to exfiltration.
- File access and archive creation events were recorded.

9. Attempted Data Exfiltration

- Outbound HTTP communications indicated an attempted data transfer.
- Network monitoring detected suspicious outbound connections.

10. Lateral Movement Activity

- SSH-based remote access was used to move between systems.
- Authentication and remote session events confirmed lateral movement attempts.

11. Multi-Source Log Correlation

- Splunk, Wazuh, Sysmon, Snort IDS, pfSense, and operating system logs provided complete visibility into attacker activities.
- Cross-correlation improved investigation accuracy and reduced false positives.

12. Threat Intelligence Validation

- Indicators of Compromise (IOCs) were enriched using VirusTotal, AbuseIPDB, PhishTool, and MXToolbox.
- External intelligence confirmed the reputation of malicious artifacts.

13. MITRE ATT&CK Mapping

- All attacker behaviors were successfully mapped to the MITRE ATT&CK Framework, providing standardized classification of tactics and techniques.

14. Incident Response Effectiveness

- The attack was successfully detected, investigated, contained, eradicated, and the affected environment was restored following the NIST SP 800-61 Incident Response Lifecycle.

5. Technical Investigation

5.1 Reconnaissance

Objective

Identify publicly accessible resources and potential attack surfaces on the target web application.

Activity

The attacker used **Gobuster** to enumerate hidden directories and files. The high volume of HTTP requests triggered security alerts, indicating automated reconnaissance.

Detection

- **Wazuh:** Detected abnormal web enumeration activity.
- **Apache Logs:** Recorded repeated HTTP requests and response codes.

MITRE ATT&CK

Tactic	Technique	ID
Reconnaissance	Active Scanning	T1595

Key Findings

- Automated directory enumeration identified.
- Reconnaissance originated from the Kali Linux host.
- Early detection provided visibility before exploitation.

Evidence

```
(kali@kali)-[~]
└─$ gobuster dir \
  -u http://192.168.56.107 \
  -w /usr/share/wordlists/dirb/common.txt \
  -x txt,php,html,bak

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.107
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,php,html,bak
[+] Timeout: 10s

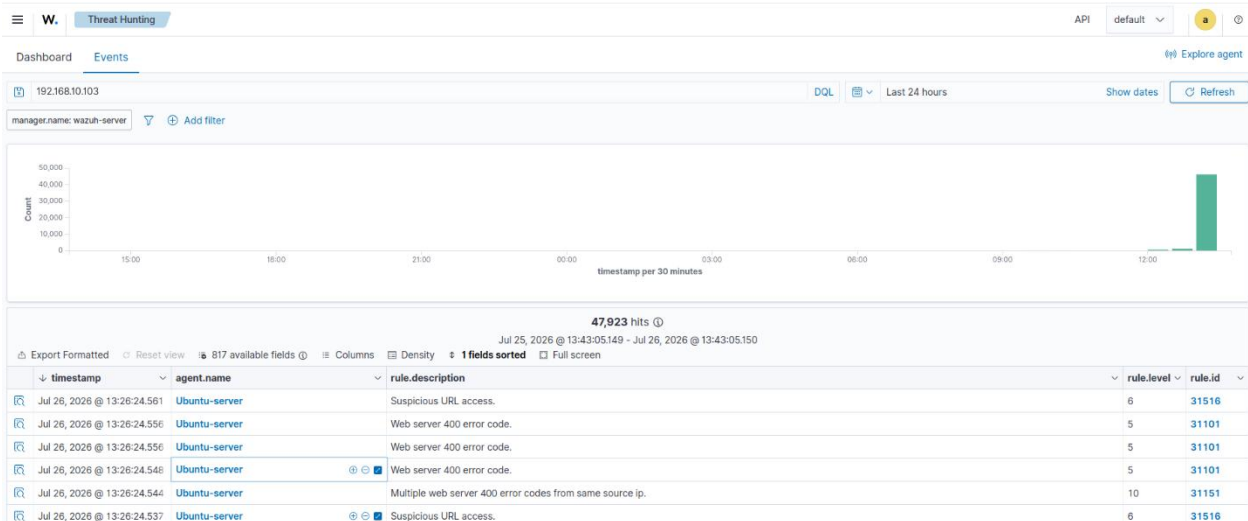
Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 10739]
index.html (Status: 200) [Size: 10739]
Progress: 23065 / 23065 (100.00%)

Finished

(kali@kali)-[~]
└─$
```

Figure 4 – Wazuh Reconnaissance Alert



5.2 Initial Access

Objective

Gain unauthorized access through phishing and compromised credentials.

Activity

A phishing email was analyzed using email forensics and threat intelligence. The attacker then authenticated to the Ubuntu server via SSH using compromised credentials.

Detection

- **Wazuh:** Successful and failed SSH logins.
- **Splunk:** Authentication and session correlation.
- **Threat Intelligence:** Email and URL validation.

MITRE ATT&CK

Tactic	Technique	ID
Initial Access	Phishing	T1566
Initial Access	Valid Accounts	T1078

Key Findings

- Phishing email confirmed as the initial attack vector.
- Unauthorized SSH access established.
- Authentication events correlated across multiple sources.

Evidence

Figure 5 – Phishing Email Analysis

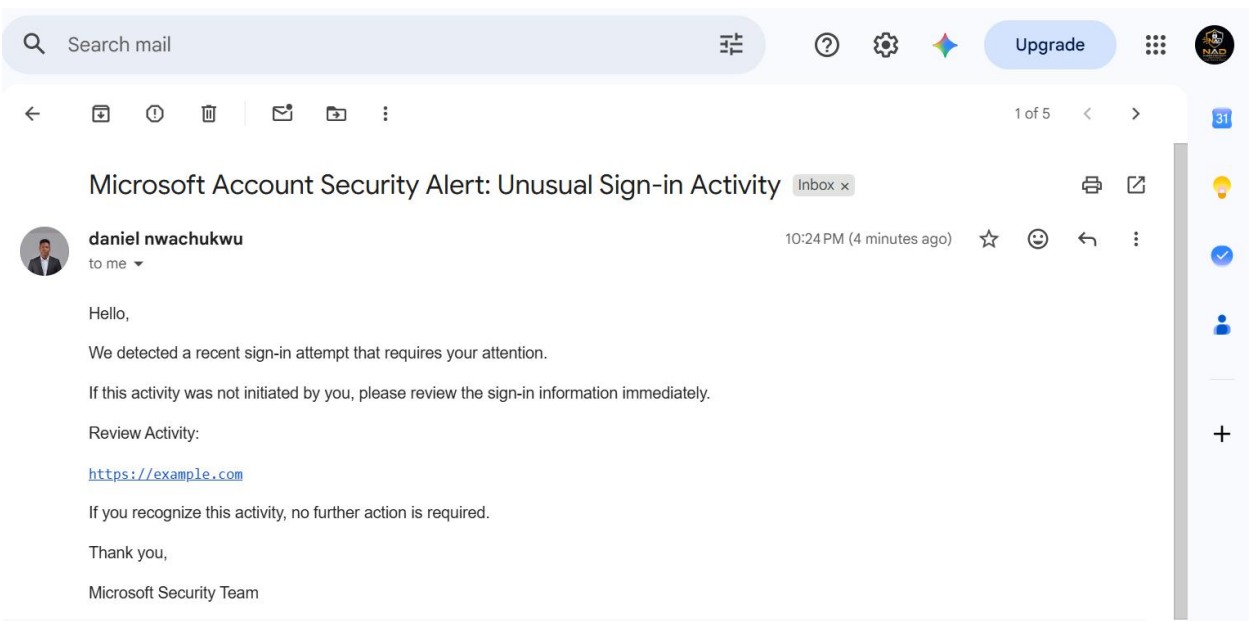
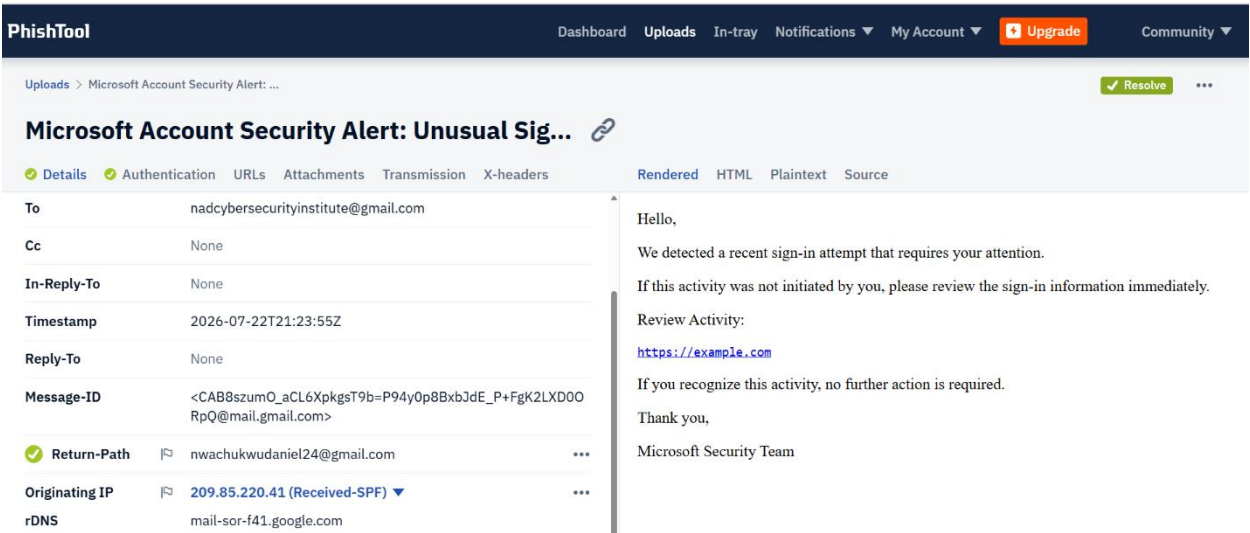


Fig 6—Phishtool Email Analysis



The phishing email claimed to be a **Microsoft Account Security Alert**, warning of an unusual sign-in attempt and urging the recipient to review account activity via a hyperlink. Analysis in PhishTool revealed sender details, originating IP address, email headers, and embedded URLs, which were examined to identify phishing indicators and assess the email's legitimacy.

5.4 IOC Investigation Summary – IP Address: 209.85.220.41

The IP address 209.85.220.41 was investigated as an Indicator of Compromise (IOC) using VirusTotal, AbuseIPDB, and WHOIS. VirusTotal reported 0/91 security vendors detecting the IP as malicious, indicating no current blacklist detections. WHOIS identified the address as belonging to Google LLC (AS15169), confirming it is part of Google's infrastructure. AbuseIPDB also showed no active abuse confidence score, although historical reports were reviewed as part of the investigation.

Based on the available evidence, the IP appears to be a legitimate Google-owned infrastructure address rather than a confirmed malicious host. However, because it was observed during the phishing investigation, it was retained as an IOC for contextual analysis and correlated with other artifacts—including email headers, domains, URLs, and log events—to determine its relevance within the attack timeline.

Figure 7- Virus Total Enrichment

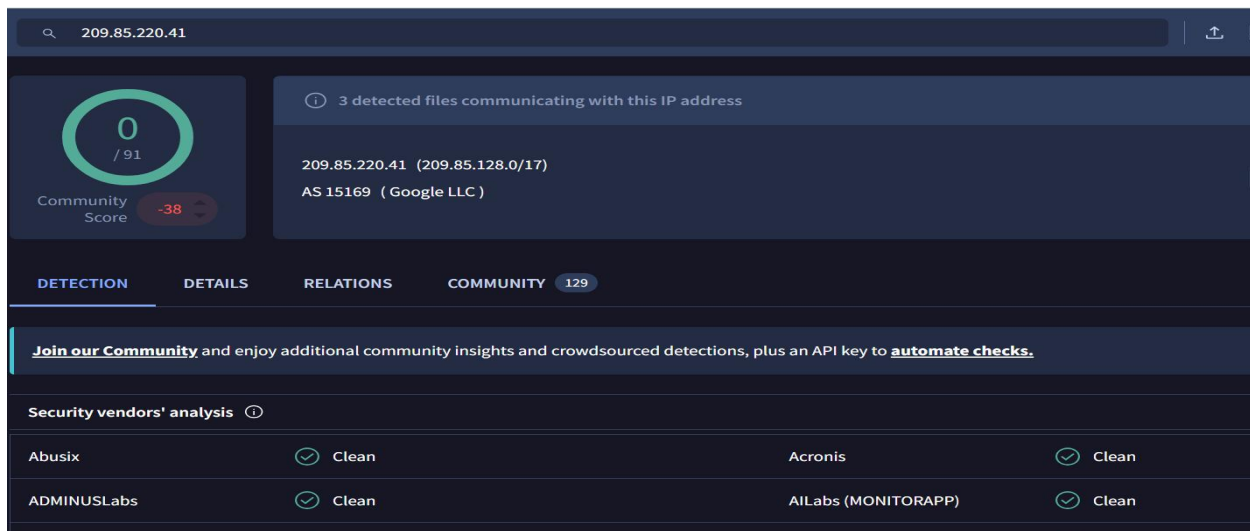


Figure 8

209.85.220.41			
Communicating Files (3)			
Scanned	Detections	Type	Name
2025-08-28	54 / 72	Win32 EXE	konut 1.exe
2025-08-28	54 / 72	Win32 EXE	WinRAR
2025-08-28	62 / 72	Win32 EXE	Client.exe
Files Referring (200)			
Scanned	Detections	Type	Name
2026-07-23	1 / 59	GZIP	installer
2026-07-23	1 / 55	TAR	localfile~
2026-07-22	1 / 62	Email	784c0d904d34df77cba03690161bb002d38bfba516ffb1430d6dcff67c1f0971
2026-07-20	1 / 61	GZIP	installer
2026-07-20	1 / 61	TAR	localfile~
2026-07-17	1 / 59	TAR	localfile~
2026-07-15	1 / 58	GZIP	installer
2026-07-11	1 / 60	TAR	localfile~
2026-07-10	1 / 61	Email	b2a9420090a5aabb53a444dd77181a2817b6cfe71bf586db71160a175d6706f9
2026-07-10	1 / 61	GZIP	installer

Figure 9

AbuseIPDB » [WHOIS 209.85.220.41](#)

Check an IP Address, Domain Name, Subnet, or ASN
e.g. 102.90.101.230, microsoft.com, 5.188.10.0/24, or AS15169

209.85.220.41

CHECK

209.85.220.41 IP Address Information

ISP

Google LLC

Usage Type

Data Center/Web Hosting/Transit

Hostname

mail-sor-f41.google.com

Domain Name

google.com

Country

 Finland

SPONSOR

Netlify One gateway for evey AI model

Figure 10

The screenshot shows the AbuseIPDB website interface. At the top, there is a navigation bar with the AbuseIPDB logo and links for Report IP, Bulk Checker, Bulk Reporter, Pricing, Integrations, Docs, and IP. Below the navigation bar, the main heading reads "AbuseIPDB » 209.85.220.41". A green banner contains the text "Check an IP Address, Domain Name, Subnet, or ASN e.g. 102.90.101.230, microsoft.com, 5.188.10.0/24, or AS15169" and a search input field with the value "209.85.220.41". The search results are displayed in a light gray box. It states "209.85.220.41 was found in our database!". Below this, it says "This IP was reported 411 times. Confidence of Abuse is 0%:" followed by a green progress bar showing 0%. The results are organized into a table with two columns: the attribute and the value. The attributes listed are ISP, Usage Type, and ASN. The values are Google LLC, Data Center/Web Hosting/Transit, and AS15169 respectively.

Attribute	Value
ISP	Google LLC
Usage Type	Data Center/Web Hosting/Transit
ASN	AS15169

Figure 10

The screenshot shows the detailed report for IP 209.85.220.41 on the AbuseIPDB website. The navigation bar at the top includes the AbuseIPDB logo and links for Report IP, Bulk Checker, Bulk Reporter, Pricing, Integrations, Docs, IP Utilities, Contact, and More. There are also links for Login and Sign Up. The main content area starts with an "Important Note" stating that 209.85.220.41 is an IP address from within our whitelist belonging to the subnet 209.85.128.0/17, which we identify as: "Google non-cloud IPs". Below this, there is a paragraph explaining that whitelisted netblocks are typically owned by trusted entities, such as Google or Microsoft, who may use them for search engine spiders. However, these same entities sometimes also provide cloud servers and mail services which are easily abused. Pay special attention when trusting or distrusting these IPs. Below the paragraph are two buttons: "REPORT 209.85.220.41" and "WHOIS 209.85.220.41". The next section is titled "IP Abuse Reports for 209.85.220.41:". It states that this IP address has been reported a total of 411 times from 42 distinct sources. 209.85.220.41 was first reported on March 16th 2026, and the most recent report was 17 hours ago. At the bottom, there is an orange banner with a warning icon and the text "Recent Reports: We have received reports of abusive activity from this IP address within the last week. It is potentially still actively engaged in abusive activities."

	Jul 26, 2026 @ 09:56:43.356	Ubuntu-server	sshd: authentication failed.	5	5760
	Jul 26, 2026 @ 09:56:43.355	Ubuntu-server	sshd: authentication failed.	5	5760
	Jul 26, 2026 @ 09:56:43.355	Ubuntu-server	sshd: authentication failed.	5	5760
	Jul 26, 2026 @ 09:56:43.355	Ubuntu-server	sshd: authentication failed.	5	5760

Figure 11 –Failed SSH Authentication Detection

Figure 12 – Successful SSH Authentication Following Brute-Force Attack

```
Session Actions Edit view Help
(kali@kali)~$ hydra -l vboxuser -P passwords.txt ssh://192.168.56.107
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no
n-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-26 10:21:19
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 9 tasks per 1 server, overall 9 tasks, 9 login tries (l:1/p:9), ~1 try per task
[DATA] attacking ssh://192.168.56.107:22/
[22][ssh] host: 192.168.56.107  login: vboxuser  password: password1234
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-26 10:21:23

(kali@kali)~$ ssh vboxuser@192.168.56.107
kex_exchange_identification: read: Connection reset by peer
Connection reset by 192.168.56.107 port 22

(kali@kali)~$ ssh vboxuser@192.168.56.107
vboxuser@192.168.56.107's password:
Welcome to Ubuntu 25.10 (GNU/Linux 6.17.0-41-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

124 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Your Ubuntu release is not supported anymore.
For upgrade information, please visit:
http://www.ubuntu.com/releaseendoflife

New release '26.04 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

You have new mail.
Last login: Sun Jul 26 09:59:54 2026 from 192.168.10.103
vboxuser@Ubuntu:~$ sudo -l
[sudo: authenticate] Password:
root@Ubuntu:~# whoami
root
```

New Search

source="WinEventLog:Microsoft-Windows-Sysmon/Operational"
example.com
| table _time EventCode Image QueryName QueryResults ProcessGuid ProcessId User
| sort _time

Time range: Last 24 hours

Save As Create Table View Close

2 events (7/22/26 5:00:00.000 PM to 7/23/26 5:14:06.000 PM)
No Event Sampling
Job
Smart Mode

Events Patterns Statistics (2) Visualization

Show: 20 Per Page
Format
Preview: On

_time	EventCode	Image	QueryName	QueryResults	ProcessGuid	ProcessId
2026-07-23 10:15:55.700	22	C:\Program Files\Google\Chrome\Application\chrome.exe	example.com	::ffff:104.20.23.154;::ffff:172.66.147.243;	{1a131079-a226-6a60-6601-000000006200}	
2026-07-23 11:55:38.648	22	C:\Program Files\Google\Chrome\Application\chrome.exe	example.com	::ffff:172.66.147.243;::ffff:104.20.23.154;	{1a131079-a226-6a60-6601-000000006200}	

Figure 13 – Splunk Event Correlation Confirming Malicious URL Access

Figure 14 – Wazuh Alert Confirming Successful SSH Authentication

Document Details		View surrounding documents	View single document
location	journalld		
manager.name	wazuh-server		
predecoder.hostname	Ubuntu		
predecoder.program_name	sshd-session		
predecoder.timestamp	Jul 26 09:22:20		
rule.description	sshd: authentication success.		
rule.firedtimes	2		
rule.gdpr	IV_32.2		
rule.gpg13	7.1, 7.2		
rule.groups	syslog, sshd, authentication_success		
rule.hipaa	164.312.b		
rule.id	5715		
rule.level	3		
rule.mail	false		
rule.mitre.id	T1078 T1021		
rule.mitre.tactic	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Lateral Movement		
rule.mitre.technique	Valid Accounts, Remote Services		
rule.nist_800_53	AU.14, AC.7		
rule.pci_dss	10.2.5		
rule.tsc	CC6.8, CC7.2, CC7.3		
timestamp	Jul 26, 2026 @ 10:22:19.673		

5.3 Exploitation

Objective

Exploit a vulnerable web application to gain deeper access.

Activity

The attacker used **SQLMap** to perform SQL Injection against the target application. The activity generated abnormal HTTP traffic detected by both endpoint and network monitoring tools.

Detection

- **Wazuh:** SQL Injection alerts.
- **Snort IDS:** Malicious HTTP traffic.
- **Splunk:** Event correlation.

MITRE ATT&CK

Tactic	Technique	ID
Initial Access	Exploit Public-Facing Application	T1190

Key Findings

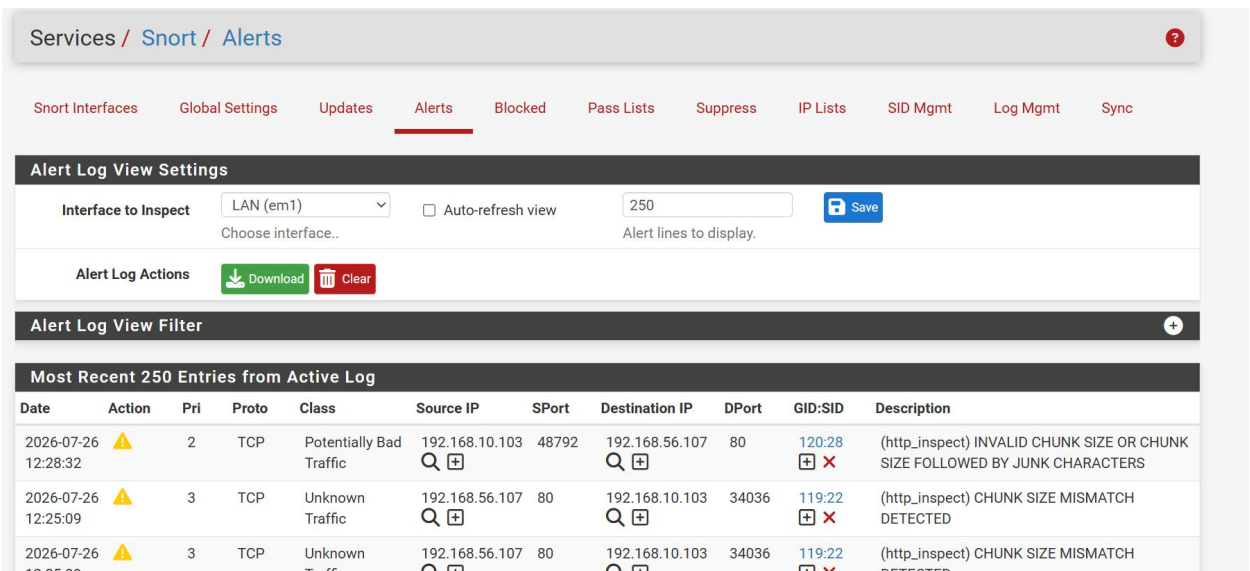
- SQL Injection attempts confirmed.
- Endpoint and network telemetry validated the attack.
- Exploitation originated from the Kali Linux host.

Evidence:

Figure 15 – Wazuh Detection of Successful SQL Injection Attack Against the Web Application

Document Details		View surrounding documents	View single document
data.scrip	192.168.10.103		
data.url	/7eIBA=6212%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%2Ctable_name%20FROM%20information_schema.tables%20WHERE%202%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20.%2F.%2F.%2Fetc%2Fpasswd%27%29%23		
decoder.name	web-accesslog		
full_log	192.168.10.103 - - [26/Jul/2026:13:11:34 +0100] "GET /7eIBA=6212%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%2Ctable_name%20FROM%20information_schema.tables%20WHERE%202%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20.%2F.%2F.%2Fetc%2Fpasswd%27%29%23 HTTP/1.1" 200 3170 "http://192.168.56.107/" "sqlmap/1.10.4#stable (https://sqlmap.org)" "-"		
id	1785067888.14713882		
input.type	log		
location	/var/log/nginx/access.log		
manager.name	wazuh-server		
rule.description	A web attack returned code 200 (success).		
rule.firedtimes	1		
rule.gdpr	IV_35.7.d		
rule.groups	web, accesslog, attack		
rule.id	31106		
rule.level	6		
rule.mail	false		
rule.mitre.id	T1190		
rule.mitre.tactic	Initial Access		
rule.mitre.technique	Exploit Public-Facing Application		

Figure 16 – Snort IDS Detecting Malicious Web Traffic During SQL Injection Attack



5.4 Privilege Escalation

Objective

Obtain elevated privileges after gaining initial access.

Activity

The attacker enumerated privileged accounts and used **sudo** to obtain root access, enabling unrestricted access to the target system.

Detection

- **Wazuh:** Privilege escalation alerts.
- **Linux Authentication Logs:** Successful sudo execution.

MITRE ATT&CK

Tactic	Technique	ID
Privilege Escalation	Abuse Elevation Control Mechanism	T1548

Key Findings

- Root privileges successfully obtained.
- Elevated access increased the attacker's control over the system.

Evidence

Figure 17 – Wazuh Alert Confirming Successful Root Privilege Escalation

```
Session Actions Edit View Help
(kali@kali)-[~]
$ hydra -l vboxuser -P passwords.txt ssh://192.168.56.107
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no
n-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-26 10:21:19
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 9 tasks per 1 server, overall 9 tasks, 9 login tries (l:1/p:9), ~1 try per task
[DATA] attacking ssh://192.168.56.107:22/
[22][ssh] host: 192.168.56.107 login: vboxuser password: password1234
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-26 10:21:23

(kali@kali)-[~]
$ ssh vboxuser@192.168.56.107
vboxuser@192.168.56.107's password:
Welcome to Ubuntu 25.10 (GNU/Linux 6.17.0-41-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

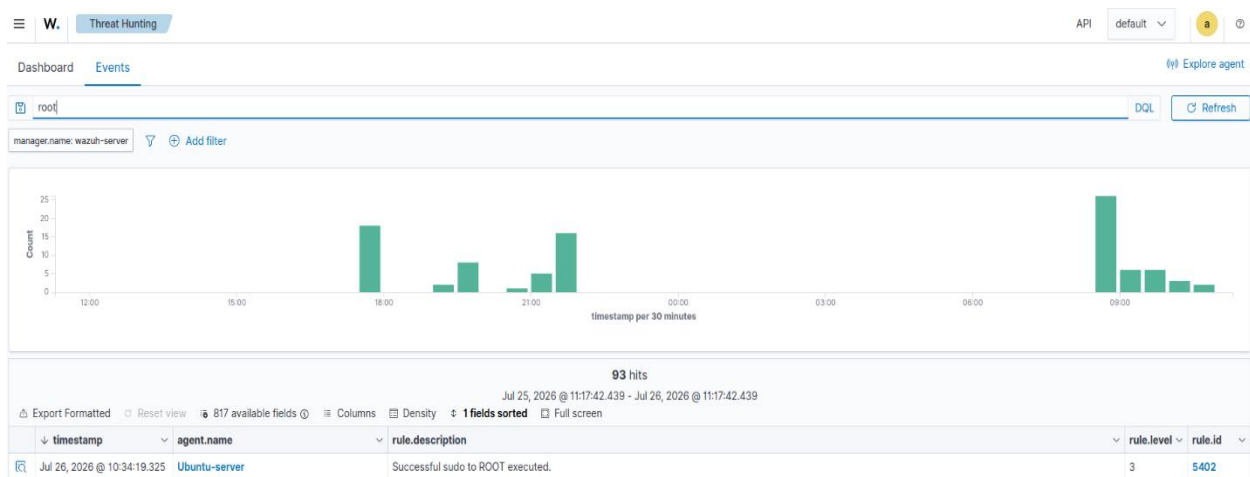
124 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Your Ubuntu release is not supported anymore.
For upgrade information, please visit:
http://www.ubuntu.com/releaseendoflife

New release '26.04 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

You have new mail.
Last login: Sun Jul 26 09:59:54 2026 from 192.168.10.103
vboxuser@Ubuntu:~$ sudo -i
[sudo: authenticate] Password:
root@Ubuntu:~# whoami
root
```

Figure 18



5.5 Persistence

Objective

Maintain long-term access to the compromised system.

Activity

Persistence was established by creating a scheduled **cron** job and modifying the **authorized_keys** file to allow future SSH access.

Detection

- **Wazuh:** File integrity and configuration change alerts.
- **Splunk:** Cron and SSH-related log events.

MITRE ATT&CK

Tactic	Technique	ID
Persistence	Scheduled Task/Cron	T1053.003
Persistence	SSH Authorized Keys	T1098.004

Key Findings

- Multiple persistence mechanisms identified.
- Unauthorized system modifications confirmed.

Evidence

Figure 19 – Splunk Detection of SSH Persistence via `authorized_keys` Modification

The screenshot displays the Splunk Search interface. At the top, the search bar contains the query: `index=* sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" authorized_keys`. Below the search bar, it indicates 10 events were found for the time range from 7/26/26 12:00:00.000 AM to 7/27/26 12:00:00.000 AM. The results are shown in a table view with columns for Time and Event. The event details show a modification to the `authorized_keys` file in the `C:\Users\DANIEL\.ssh\` directory, performed by `icaccls.exe` from `C:\WINDOWS\system32\`. The event also includes fields for `host`, `source`, and `CurrentDirectory`.

Time	Event
7/26/26 2:56:51.569 PM	07/26/2026 02:56:51.569 PM ... 22 lines omitted ... Company: Microsoft Corporation OriginalFileName: icaccls.exe CommandLine: "C:\WINDOWS\system32\icaccls.exe" C:\Users\DANIEL\.ssh\authorized_keys.txt /grant DANIE L:F CurrentDirectory: C:\WINDOWS\system32\ Show all 38 lines host = DESKTOP-SIVVO9B source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = WinEventLog:Microsoft-Windows-Sysmon/Operational

```

root@Ubuntu:~# crontab -e
no crontab for root - using an empty one
Select an editor. To change later, run select-editor again.
 1. /bin/nano          ← easiest
 2. /usr/bin/vim.tiny
 3. /bin/ed
Choose 1-3 [1]: 1
crontab: installing new crontab
root@Ubuntu:~# crontab -l
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
*/10 * * * * echo "heartbeat from attacker" >> /tmp/.heartbeat.log
root@Ubuntu:~#

```

Figure 20 – Establishing Persistence Through a Malicious Cron Job

5.6 Defense Evasion

Objective

Avoid detection while executing malicious activities.

Activity

The attacker executed **encoded PowerShell commands** and leveraged legitimate system utilities (LOLBins) to disguise malicious activity.

Detection

- **Sysmon:** Process creation events.
- **Splunk:** Encoded PowerShell execution.
- **Wazuh:** Suspicious process activity.

MITRE ATT&CK

Tactic	Technique	ID
Defense Evasion	Obfuscated Files or Information	T1027
Defense Evasion	PowerShell	T1059.001
Defense Evasion	System Binary Proxy Execution	T1218

Key Findings

- Encoded PowerShell activity detected.
- Legitimate system binaries were abused to evade detection.
- Multi-source log correlation confirmed the evasion techniques.

Evidence

Figure 21 – Encoded PowerShell Detection

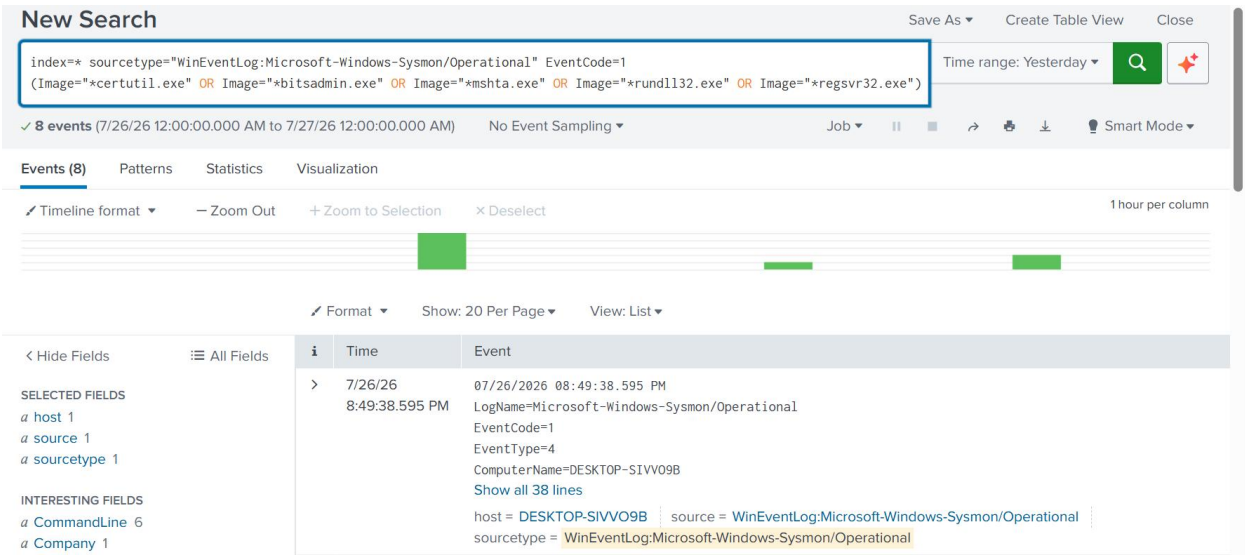
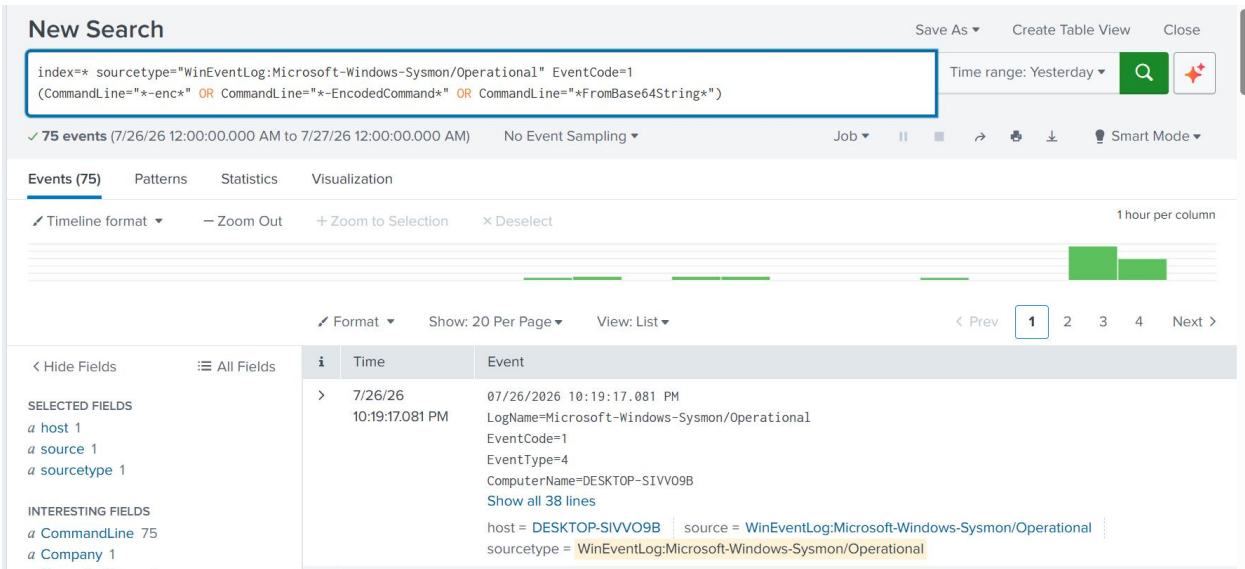


Figure 22



5.7 Discovery

Objective

Identify users, system information, network configuration, and sensitive resources.

Activity

The attacker executed system enumeration commands to gather information about users, directories, network interfaces, and running services.

Detection

- **Splunk:** Command execution logs.
- **Sysmon:** Process creation events.
- **Wazuh:** Shell activity monitoring.

MITRE ATT&CK

Tactic	Technique	ID
Discovery	System Owner/User Discovery	T1033
Discovery	File and Directory Discovery	T1083

Tactic	Technique	ID
Discovery	System Network Configuration Discovery	T1016

Key Findings

- User and system information successfully enumerated.
- Network and file structure identified.
- Activity confirmed through endpoint telemetry.

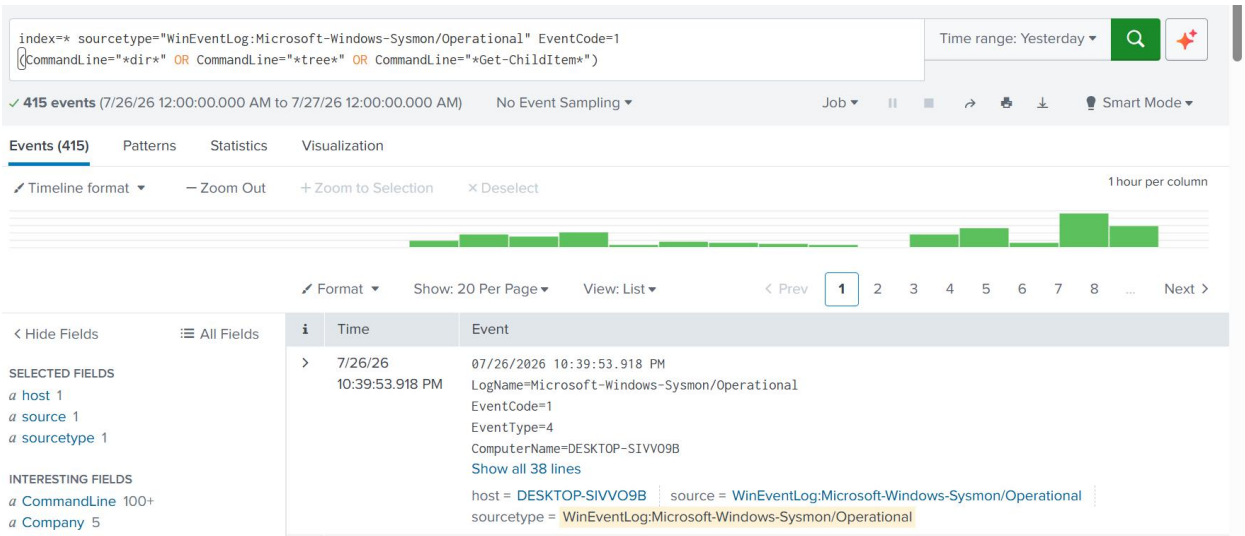
Evidence Figure 23

```

root@Ubuntu:~# find / -perm -4000 2>/dev/null
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/pkexec
/usr/bin/sudo.ws
/usr/bin/ntfs-3g
/usr/bin/su
/usr/bin/fusermount3
/usr/bin/mount
/usr/sbin/pppd
/usr/lib/openssh/ssh-keysign
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/cargo/bin/sudo
/usr/lib/cargo/bin/su
/snap/core24/1643/usr/bin/chfn
/snap/core24/1643/usr/bin/chsh
/snap/core24/1643/usr/bin/gpasswd
/snap/core24/1643/usr/bin/mount
/snap/core24/1643/usr/bin/newgrp
/snap/core24/1643/usr/bin/passwd
/snap/core24/1643/usr/bin/su
/snap/core24/1643/usr/bin/sudo
/snap/core24/1643/usr/bin/umount
/snap/core24/1643/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core24/1643/usr/lib/openssh/ssh-keysign
/snap/core24/1643/usr/lib/polkit-1/polkit-agent-helper-1
/snap/core22/2411/usr/bin/chfn
/snap/core22/2411/usr/bin/chsh
/snap/core22/2411/usr/bin/gpasswd
/snap/core22/2411/usr/bin/mount
/snap/core22/2411/usr/bin/newgrp
/snap/core22/2411/usr/bin/passwd
/snap/core22/2411/usr/bin/su
/snap/core22/2411/usr/bin/sudo
/snap/core22/2411/usr/bin/umount
/snap/core22/2411/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core22/2411/usr/lib/openssh/ssh-keysign
/snap/core22/2411/usr/libexec/polkit-agent-helper-1
root@Ubuntu:~# mkdir file1
root@Ubuntu:~# mkdir file2
root@Ubuntu:~# mkdir file3
root@Ubuntu:~# █

```

Figure 24 – Discovery Commands and SIEM Detection



5.8 Collection

Objective

Locate and stage sensitive files for exfiltration.

Activity

The attacker searched for valuable files and archived them into a compressed file prior to data transfer.

Detection

- **Splunk:** File access events.
- **Wazuh:** Archive creation activity.

MITRE ATT&CK

Tactic Technique ID

Collection Data from Local System T1005

Collection Archive Collected Data T1560

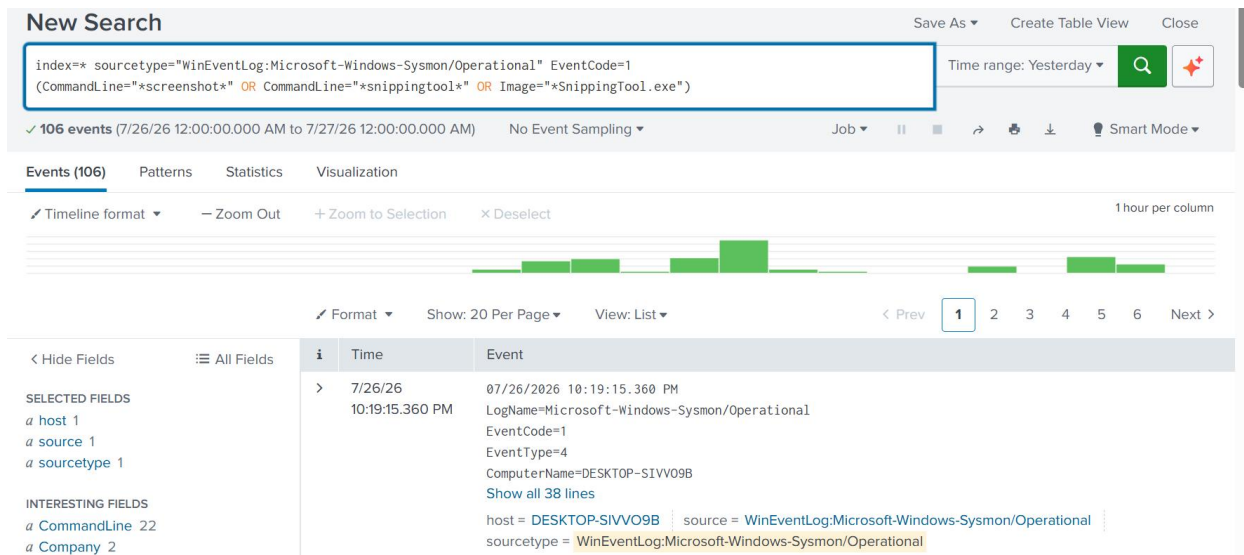
Key Findings

- Sensitive files identified.
- Data prepared for exfiltration.

- Collection activity detected before data transfer.

Evidence

Figure 25 – File Collection Activity



5.9 Exfiltration

Objective

Transfer collected data outside the compromised environment.

Activity

The attacker attempted to exfiltrate archived data over HTTP using PowerShell-based web requests.

Detection

- **Splunk:** Outbound HTTP activity.
- **Wazuh:** Suspicious network connections.
- **Sysmon:** Network connection events.

MITRE ATT&CK

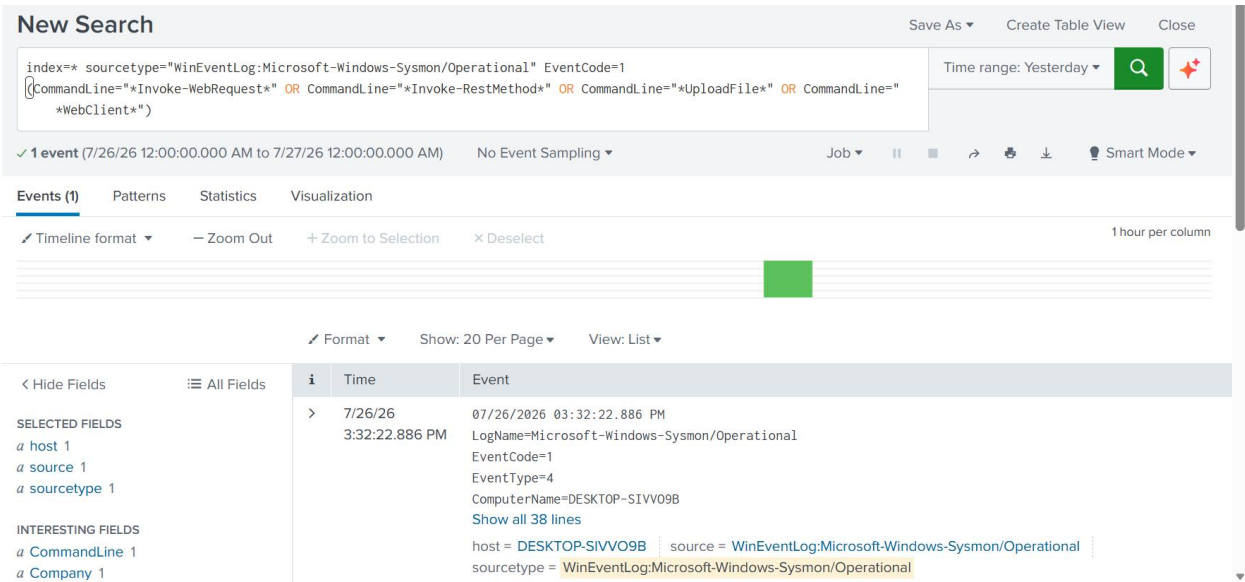
Tactic	Technique	ID
Exfiltration	Exfiltration Over Web Service	T1567
Command and Control	Application Layer Protocol	T1071.001

Key Findings

- Outbound data transfer attempt detected.
- Network telemetry confirmed suspicious communication.
- Exfiltration was identified before completion.

Evidence

Figure 26 – Exfiltration Detection



5.10 Lateral Movement

Objective

Move from the compromised host to additional systems within the network.

Activity

The attacker used SSH and remote administrative services to access other systems after obtaining elevated privileges.

Detection

- **Splunk:** Remote authentication events.
- **Sysmon:** Remote process execution.
- **Wazuh:** SSH session monitoring.

MITRE ATT&CK

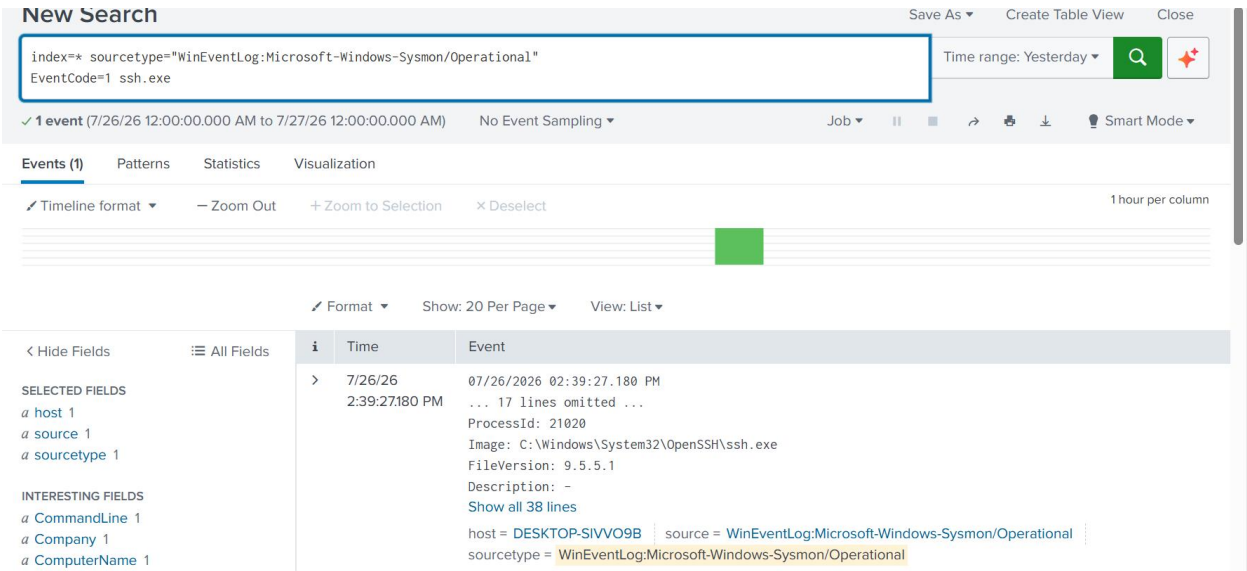
Tactic	Technique	ID
Lateral Movement	Remote Services	T1021
Lateral Movement	SSH	T1021.004

Key Findings

- Unauthorized remote access attempts detected.
- Lateral movement correlated across endpoint and network logs.
- Early detection limited further compromise.

Evidence

Figure 15 – Lateral Movement Detection



6. Indicators of Compromise (IOCs)

Overview

The investigation identified multiple Indicators of Compromise (IOCs) that confirmed malicious activity across the environment. These indicators were validated through SIEM correlation, endpoint telemetry, and threat intelligence.

Indicator Type	Indicator	Source
Source IP Address	Attacker Kali-192.168.10.103	Wazuh, Splunk
Target IP Address	Ubuntu Server IP 192.168.56.107	Wazuh
Reconnaissance	Gobuster directory enumeration	Apache Logs, Wazuh
Initial Access	Suspicious SSH authentication	Wazuh, Splunk
Exploitation	SQLMap SQL Injection traffic	Snort IDS, Wazuh

Indicator Type	Indicator	Source
Privilege Escalation	sudo execution	Linux Logs
Persistence	Modified authorized_keys	Wazuh
Persistence	Unauthorized cron job	Splunk
Defense Evasion	Encoded PowerShell	Sysmon, Splunk
Discovery	User and network enumeration commands	Splunk
Collection	Compressed archive creation	Wazuh
Exfiltration	Outbound HTTP connection	Splunk
Lateral Movement	SSH remote access	Wazuh, Sysmon

7. Containment, Eradication, and Recovery

Containment

Immediate actions were taken to prevent further compromise:

- Isolated the affected systems.
- Blocked malicious SSH sessions.
- Preserved logs for forensic analysis.
- Increased monitoring across all security platforms.

Eradication

The attacker's foothold was removed by:

- Deleting unauthorized cron jobs.
- Removing malicious SSH keys.
- Resetting compromised credentials.
- Verifying the removal of persistence mechanisms.

Recovery

Normal operations were restored after security validation:

- Systems were returned to service.
- Monitoring confirmed no recurring malicious activity.
- Security controls remained active for continued observation.
- A post-incident review was conducted to identify improvements.

8. Security Recommendations

Based on the investigation, the following recommendations are proposed to reduce the risk of similar incidents.

Recommendation	Benefit
Implement Multi-Factor Authentication (MFA)	Prevent unauthorized account access.
Enforce regular patch management	Reduce exposure to known vulnerabilities.
Deploy a Web Application Firewall (WAF)	Detect and block web-based attacks such as SQL Injection.
Apply the Principle of Least Privilege	Limit the impact of compromised accounts.
Conduct regular security awareness training	Reduce phishing success rates.
Centralize log monitoring with SIEM	Improve threat detection and incident response.
Enable File Integrity Monitoring (FIM)	Detect unauthorized file modifications.
Perform routine vulnerability assessments	Identify and remediate security weaknesses proactively.

9. Lessons Learned

The investigation highlighted several important security lessons:

- Early detection significantly reduced the attack's impact.
- Correlating logs from multiple security tools improved investigation accuracy.
- Continuous endpoint and network monitoring enhanced visibility across the attack lifecycle.
- Strong authentication and least-privilege access are critical to limiting attacker movement.
- Regular user awareness training remains one of the most effective defenses against phishing.

10. Conclusion

This investigation successfully reconstructed a simulated enterprise phishing attack from initial reconnaissance through recovery. Using Splunk Enterprise, Wazuh SIEM, Sysmon, Snort IDS, and pfSense, the attack was detected, analyzed, contained, and remediated.

The project demonstrates practical skills in security monitoring, log correlation, threat hunting, digital forensics, and incident response while applying industry best practices aligned with the **MITRE ATT&CK Framework** and the **NIST Incident Response Lifecycle**.

11. References

- MITRE ATT&CK Framework
- NIST SP 800-61 Rev. 2 – Computer Security Incident Handling Guide
- NIST Cybersecurity Framework (CSF) 2.0
- Splunk Enterprise Documentation
- Wazuh Documentation
- Microsoft Sysmon Documentation
- Snort IDS Documentation
- pfSense Documentation
- VirusTotal
- AbuseIPDB

- PhishTool
- MXToolbox